Information Security Policy

DFRNT Group Pty Ltd (ABN 21 679 198 317) trading as DFRNT Solar · 109 Robertson Street, Fortitude Valley QLD 4006
Version 0.9 (draft for director sign-off) · 1 November 2026 · Owner: Karl Brown, Director · Review: every 12 months and after any incident or major change

1. Purpose and scope

This policy sets how DFRNT Solar protects customer information, in particular Consumer Data Right (CDR) energy data received through Fiskil, an accredited data recipient. It applies to everyone who works for or with us (directors, staff, contractors and installers) and to every system that stores or processes customer data. DFRNT Solar is pre-launch. Each control below is marked **In place** or **Before go-live**; no live CDR data will be received until every "Before go-live" control is in place.

2. Roles

- **Director (Karl Brown)**: accountable for security; approves this policy, access and vendors; security and privacy contact.
- **Staff**: follow this policy; report anything suspicious immediately.
- **Installers (subcontractors)**: see only the install details for their own jobs; bound by their subcontract's confidentiality terms.

3. Controls

Area	Requirement	Status
Data minimisation	Request only usage, NMI standing data, plan/tariff and DER. No billing, payments, concessions or personal details from the retailer. Use CDR data only to size, price and support the customer's own system. Never sell, share or use it for marketing.	**In place**
Hosting and location	Production application on Vercel with functions pinned to Sydney (syd1); database on Supabase, Sydney (ap-southeast-2). CDR data is not stored outside Australia.	**In place**
Encryption	TLS 1.2 or higher for all traffic (HTTPS only, HSTS enforced). Data at rest encrypted by the database provider (AES-256). Secrets (API keys) held only as encrypted environment variables, never in code or chat.	**In place**
Access control	Least privilege. CDR data is read only by server code. Customers see only their own results via an unguessable link. Installers see install figures for their own jobs only. Staff admin requires sign-in with two-factor authentication. Access is granted and removed by the Director and reviewed quarterly.	**In place**
Multi-factor authentication	MFA required on every account that can reach production or customer data: Vercel, Supabase, GitHub, Fiskil console, Google Workspace, our admin area.	**Before go-live**
Devices	Work devices must have full-disk encryption, screen lock, automatic OS and browser updates, and built-in anti-malware turned on. No customer data is downloaded to devices.	**Before go-live**
Change management	All code in a private GitHub repository. Every change runs automated tests before it deploys; only the main branch deploys to production through Vercel; every deployment is logged and can be rolled back. Database changes are versioned migrations.	**In place**
Secure coding	Server-side validation of all inputs; parameterised database queries; prices and rebates computed on the server; Content-Security-Policy and security headers; analytics and ad tags excluded from private pages.	**In place**
Vulnerability management	Dependency vulnerability alerts on the repository; critical issues patched within 7 days, high within 30 days.	**Before go-live**
Logging and monitoring	Platform request and function logs (Vercel); application audit trail of job and status changes; Fiskil connection log. Alerts on errors and unusual access to the Director.	Logs **in place**; alerting **before go-live**
Retention and deletion	Raw half-hour readings deleted automatically after 30 days. Summary and sizing kept while consent is active; deleted when the customer withdraws (from their page, Fiskil or the retailer). Consent lasts 12 months at most.	**In place**

Vendors	Vendors that host customer data are approved by the Director and listed in our vendor register with location and purpose: Vercel, Supabase, Fiskil. GitHub (code only) and Resend (email; no CDR data). Reviewed yearly.	**Before go-live**
People	Security and privacy training at onboarding and yearly; confidentiality obligations in employment and subcontract terms; police checks for staff with admin access.	**Before go-live**
AI	No AI or machine learning system receives, processes or is trained on CDR data.	**In place**
Independent testing	External penetration test of the web application before or within 6 months of launch.	**Before go-live / 6 months**

4. Incident response

- **Report**: anyone who suspects a breach tells the Director at once (hello@dfrntsolar.com.au, 1300 133 768).
- **Contain**: revoke affected keys and sessions, rotate Fiskil credentials, pause data pulls (Ops switch), preserve logs.
- **Assess**: what data, whose, how many, how it happened.
- **Notify**: Fiskil within 24 hours of becoming aware; affected customers and the OAIC under the Notifiable Data Breaches scheme where required.
- **Fix and review**: root cause, fix, update this policy; record kept for 7 years.

5. Approval

Approved by: _____ Karl Brown, Director Date: _____